

Chapitre 9

La lutte contre le blanchiment et le financement du terrorisme

Feuille d'exercices

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Exercices du chapitre

Exercice 1 — Le cadre GAFI-Bâle, l'évaluation du risque et la gouvernance AML/CFT

- (a) Le cours précise que les lignes directrices du Comité de Bâle sur le contrôle bancaire (BCBS) « sont conçues pour être cohérentes avec [les standards du GAFI] et les compléter, sans jamais les affaiblir ni les renforcer unilatéralement — le Comité disposant d'un statut d'observateur auprès du GAFI ». Expliquer précisément ce que cette triple contrainte (cohérence, complémentarité, absence d'affaiblissement *ou* de renforcement unilatéral) interdit concrètement au Comité de Bâle de faire. En quoi le « statut d'observateur » du Comité auprès du GAFI — plutôt qu'un statut de membre à part entière ou d'organisme concurrent — explique-t-il cette contrainte de non-renforcement unilatéral ?
- (b) Le cours affirme que « l'insuffisance de la gestion du risque ML/FT expose une banque à des risques réputationnel, opérationnel, de conformité et de concentration sévères », ce qui justifie, selon le cours, que le Comité de Bâle « traite ce risque comme une composante à part entière de la solidité bancaire, et non comme une simple obligation de conformité externe ». Pour chacun des quatre risques cités (réputationnel, opérationnel, de conformité, de concentration), donner un mécanisme concret par lequel une défaillance ML/FT pourrait le matérialiser. En quoi cette énumération de risques *multiples et interconnectés* soutient-elle spécifiquement l'argument selon lequel le risque ML/FT engage la « solidité bancaire » plutôt qu'une simple conformité réglementaire isolée ?
- (c) Le cours exige que chaque banque développe « une compréhension approfondie des risques ML/FT inhérents à sa base de clientèle, ses produits, ses canaux de distribution et les juridictions dans lesquelles elle-même ou ses clients opèrent », à partir de « données opérationnelles et transactionnelles internes ainsi que sur des sources externes », le **risque résiduel** devant « rester cohérent avec le profil de risque global de l'établissement ». Distinguer précisément le risque inhérent du risque résiduel à partir de cette définition. Pourquoi une évaluation « propre à chaque établissement » est-elle nécessaire ici, plutôt qu'un référentiel unique de risques ML/FT applicable uniformément à toutes les banques indépendamment de leur clientèle, leurs produits, leurs canaux et leurs juridictions ?
- (d) Le cours exige un « responsable en chef de la conformité AML/CFT (chief AML/CFT officer), doté d'une autorité et d'un statut suffisants pour que les problèmes identifiés soient traités avec le sérieux requis et remontés rapidement », tandis que « l'audit interne doit évaluer périodiquement le système de surveillance informatisé pour s'assurer qu'il est utilisé effectivement par les première et deuxième lignes de défense » — « un rappel du modèle des trois lignes de défense déjà rencontré au chapitre 1, appliqué ici spécifiquement au risque ML/FT ». Identifier, dans ces deux exigences, laquelle relève de la gouvernance opérationnelle du dispositif (deuxième ligne) et laquelle relève de son assurance indépendante (troisième ligne). Pourquoi le cours insiste-t-il sur une vérification de l'usage *effectif* du système de surveillance par l'audit interne, plutôt que de se contenter de vérifier l'existence formelle de ce système ?

Exercice 2 — Accepter le client : identification et diligence renforcée

- (a) La politique d'acceptation des clients doit identifier les profils à risque élevé en tenant compte de facteurs tels que « le profil professionnel du client (y compris une éventuelle position politiquement exposée), son origine géographique, la nature et l'objet du compte, ou encore les activités professionnelles exercées », mais « ne doit toutefois jamais être si restrictive qu'elle prive d'accès aux services bancaires les personnes financièrement ou socialement défavorisées — un principe explicitement rappelé par la Guidance sur l'inclusion financière du GAFI ». Expliquer pourquoi le cours qualifie cette politique de « profil de risque par facteurs, non par catégories rigides » : en quoi une approche par facteurs évite-t-elle précisément l'écueil d'une exclusion financière que redoute la Guidance du GAFI, là où une catégorisation rigide (par exemple, un refus automatique fondé sur la seule origine géographique) ne l'éviterait pas ?

- (b) Le cours pose qu'« une banque ne doit établir de relation d'affaires ni effectuer de transaction avant que l'identité du client, de tout mandataire agissant en son nom, et du ou des bénéficiaires effectifs, n'ait été établie et vérifiée de manière satisfaisante », et précise qu'« un compte numéroté, s'il offre une confidentialité additionnelle à son titulaire, doit rester soumis aux mêmes procédures de diligence raisonnable que tout autre compte : l'anonymat pur et simple n'est jamais admissible ». Distinguer les trois identités à établir et vérifier avant toute relation d'affaires (client, mandataire, bénéficiaire effectif). Pourquoi le cas du compte numéroté est-il spécifiquement traité par le cours : quelle confusion ce type de compte pourrait-il entretenir, en l'absence de cette précision explicite, entre confidentialité *additionnelle* et anonymat *intégral* ?
- (c) Le cours exige une diligence renforcée « lorsque le risque est jugé plus élevé — par exemple pour un client planifiant un solde de compte important assorti de virements transfrontaliers réguliers, ou pour une personne politiquement exposée étrangère », incluant « une approbation par la direction générale avant l'entrée en relation ou sa poursuite ». Pourquoi ces deux exemples de clients à risque élevé (solde important avec virements transfrontaliers réguliers ; PPE étrangère) partagent-ils un même besoin de diligence renforcée, alors que leurs profils de risque sont *a priori* de nature différente (l'un tenant à un comportement transactionnel, l'autre à un statut personnel) ? En quoi l'exigence d'une approbation par la *direction générale* — plutôt que par le seul gestionnaire de compte ou le seul responsable de conformité — traduit-elle concrètement le niveau de risque accru associé à ces profils ?
- (d) Le cours définit la surveillance continue comme reposant sur « la compréhension de l'activité bancaire normale et raisonnable de chaque client, seule à même de permettre l'identification des transactions inhabituelles qui s'en écartent », une surveillance qui doit être « proportionnée au risque identifié lors de l'évaluation du client et renforcée pour les clients ou transactions à risque élevé ». Pourquoi la détection d'une transaction « inhabituelle » présuppose-t-elle nécessairement une compréhension préalable de ce qu'est, pour *ce client précis*, une activité « normale et raisonnable » — plutôt qu'un seuil unique et absolu de transaction suspecte applicable à tous les clients indifféremment ? Montrer que le principe de proportionnalité énoncé ici prolonge directement la politique d'acceptation par facteurs de risque du (a) : pourquoi serait-il incohérent d'appliquer un même niveau de surveillance continue à un client classé à risque élevé lors de son acceptation et à un client classé à risque standard ?

Exercice 3 — Opérations suspectes, conservation et gouvernance de groupe

- (a) Le cours exige que « le processus d'identification, d'investigation et de déclaration des transactions suspectes à la cellule de renseignement financier (FIU) [soit] clairement spécifié dans les politiques et procédures de la banque et communiqué à l'ensemble du personnel par une formation régulière », la banque devant « prendre les mesures appropriées pour atténuer le risque d'utilisation criminelle du compte, sans jamais informer, même indirectement, le client qu'une déclaration a été ou sera déposée ». Identifier les trois étapes successives du processus décrit (identification, investigation, déclaration). En quoi l'interdiction absolue d'informer le client, « même indirectement », complique-t-elle la mise en œuvre concrète des « mesures appropriées pour atténuer le risque d'utilisation criminelle du compte » évoquées dans la même phrase : quel type de mesure la banque pourrait-elle prendre sans que le client ne puisse en déduire qu'une déclaration a été ou sera déposée ?
- (b) Le cours impose que « toutes les informations obtenues dans le cadre de la diligence raisonnable [soient] conservées au minimum cinq ans après la fin de la relation bancaire ou de la transaction occasionnelle — une durée qui peut être prolongée en cas de litige ou d'enquête en cours, jusqu'à la clôture définitive de l'affaire ». Pourquoi ce délai est-il calculé à partir de la *fin* de la relation bancaire (ou de la transaction occasionnelle), plutôt qu'à partir de la date d'ouverture du compte ou de la date de chaque transaction individuelle ? En quoi la clause de prolongation « en cas de litige ou d'enquête en cours, jusqu'à la clôture définitive de l'affaire » révèle-t-elle que le délai de cinq ans constitue un plancher minimal plutôt qu'un plafond ferme ?
- (c) Le cours exige qu'une banque opérant dans plusieurs juridictions développe « des politiques

et procédures AML/CFT à l'échelle du groupe, appliquées de manière cohérente », précisant que « lorsque les exigences locales de la juridiction d'accueil sont plus strictes que celles du groupe, la politique du groupe doit permettre à la succursale ou filiale concernée d'adopter les exigences locales ; à l'inverse, si la juridiction d'accueil ne permet pas la mise en œuvre adéquate des standards du groupe, des mesures additionnelles doivent être envisagées, pouvant aller jusqu'à la fermeture des opérations dans ce pays ». Distinguer précisément les deux cas de figure envisagés par le cours (exigences locales plus strictes ; exigences locales empêchant les standards du groupe) et la réponse que le cours prescrit dans chacun. Pourquoi la fermeture des opérations dans un pays constitue-t-elle, selon cette logique, une mesure de dernier recours plutôt qu'une option immédiatement envisagée dès qu'un écart apparaît entre standard du groupe et exigences locales ?

- (d) Le cours confie à un « responsable AML/CFT pour l'ensemble du groupe [...] l'autorité de donner des instructions à toutes les succursales, filiales et entités subordonnées », mais constate que le partage d'information au sein du groupe « se heurte [...] dans certaines juridictions à des lois locales de protection des données perçues comme un obstacle — un défi que le Comité de Bâle reconnaît explicitement comme plus prégnant pour la gestion du risque ML/FT que pour la plupart des autres processus de gestion des risques bancaires ». Les groupes financiers mixtes, quant à eux, doivent « surveiller et partager l'information relative aux clients et activités à risque élevé à travers l'ensemble du groupe, tout en tenant compte des différences légitimes dans les exigences AML/CFT applicables selon le secteur d'activité concerné ». En quoi l'autorité *formelle* d'instruction du responsable AML/CFT groupe peut-elle se heurter, dans les faits, à un obstacle *informationnel* que cette autorité formelle ne suffit pas à lever ? Pourquoi le cours affirme-t-il que cet obstacle est « plus prégnant » pour le risque ML/FT que pour la plupart des autres processus de gestion des risques bancaires : qu'est-ce qui, dans la nature même de l'information nécessaire à la lutte contre le blanchiment (identité des clients, bénéficiaires effectifs), la rend structurellement plus sensible du point de vue de la protection des données que, par exemple, une donnée de risque de marché ou de risque de crédit agrégée ?

2 Exercice cumulatif (chapitres 9, 8, 7, 6, 5)

Exercice 4 — Le risque ML/FT à la lumière des quatre chapitres précédents

- (a) Le chapitre 8 conclut que « l'analyse post-mortem d'Equifax a identifié cinq faiblesses majeures, illustrant qu'un événement de risque opérationnel majeur résulte rarement d'une cause unique », parmi lesquelles « l'échec de mise en œuvre de la politique de gestion des correctifs : le correctif de la vulnérabilité était disponible dès le 7 mars [...] et distribué en interne à 400 employés — sans jamais être appliqué », et « une communication interne défaillante » qui a empêché l'alerte de parvenir à la bonne personne. Ce chapitre exige quant à lui que « l'audit interne évalue périodiquement le système de surveillance informatisé pour s'assurer qu'il est utilisé effectivement par les première et deuxième lignes de défense », et non simplement qu'il existe sur le papier. Montrer que cette exigence de ce chapitre est précisément le garde-fou qui aurait pu, appliqué au cas Equifax, révéler l'écart entre une politique de gestion des correctifs *formellement adoptée et distribuée* et son application *effective* — l'écart même que le chapitre 8 documente. Le chapitre 8 rappelle par ailleurs, à propos de la communication de crise d'Equifax, « les 3R de la communication de crise destinés à limiter les dommages réputationnels », une communication *publique et prompte* envers le marché. Ce chapitre exige au contraire « sans jamais informer, même indirectement, le client qu'une déclaration a été ou sera déposée », une confidentialité stricte envers le client. Expliquer pourquoi ces deux exigences de communication, en apparence contradictoires (promptitude envers un public, silence absolu envers un autre), ne le sont pas réellement : en quoi la nature du destinataire (le marché et les clients affectés, dans un cas ; le client potentiellement impliqué dans le blanchiment, dans l'autre) justifie-t-elle deux régimes de communication opposés plutôt qu'un principe général unique de transparence ?
- (b) Le chapitre 7 constate que « le partage entre régulateurs reste le moins observé, en partie

du fait de sa nature souvent informelle et bilatérale », mais documente aussi des solutions concrètes au problème plus général du partage d'information sensible : le FS-ISAC, où « les informations partagées sont anonymisées pour ne jamais permettre de remonter à la source, un principe de confidentialité jugé essentiel pour encourager la participation volontaire des membres », et l'accord Hong Kong–Singapour, fondé notamment sur la « rapidité (partage sous 24 heures en cas de risque de propagation transfrontalière) » et un « protocole de classification standardisé ». Ce chapitre affirme que le partage d'information ML/FT au sein d'un groupe « se heurte [...] à des lois locales de protection des données [...] un défi [...] plus prégnant [...] que pour la plupart des autres processus de gestion des risques bancaires ». Si l'anonymisation permet au chapitre 7 de résoudre l'essentiel de la tension entre partage et confidentialité pour le risque cyber, montrer pourquoi cette même solution ne peut pas se transposer telle quelle au partage d'information ML/FT décrit par ce chapitre : que perdrait précisément un dispositif de surveillance croisée des relations à risque élevé au sein d'un groupe bancaire si l'identité des clients et bénéficiaires effectifs partagée entre filiales devait être anonymisée à la manière du FS-ISAC ? En quoi cette impossibilité structurelle d'anonymiser la donnée elle-même explique-t-elle, mieux qu'une simple différence de maturité réglementaire, pourquoi l'obstacle est « plus prégnant » ici que pour le risque cyber ?

- (c) Le chapitre 6, en détaillant la composition typique de la deuxième ligne de défense d'une grande banque, énumère explicitement « un responsable de la lutte contre le blanchiment (voir chapitre 9) » aux côtés des directeurs des risques de crédit, de marché, de liquidité et du RSSI. Ce chapitre tient cette promesse en détaillant le « responsable en chef de la conformité AML/CFT (chief AML/CFT officer), doté d'une autorité et d'un statut suffisants », ainsi qu'un « responsable AML/CFT pour l'ensemble du groupe ». Par ailleurs, le chapitre 6 documente, à travers le cas de la Commonwealth Bank of Australia, des « défaillances sévères de culture et de gouvernance du risque, à l'origine de manquements multiples — blanchiment de capitaux, surfacturation de clients, pertes de données », le panel de l'APRA ayant identifié « une supervision insuffisante des risques non financiers émergents par le conseil, des responsabilités mal définies, une détection et une escalade tardives des incidents [...] un cadre de gestion du risque opérationnel « meilleur sur le papier qu'en pratique » ». Montrer comment chacune des exigences de gouvernance de ce chapitre — un conseil disposant d'une « compréhension claire des risques ML/FT », un chief AML/CFT officer « doté d'une autorité [...] suffisante », et un système de surveillance dont l'audit interne vérifie l'usage *effectif* — répond précisément à l'une des défaillances identifiées par l'APRA dans le cas CBA. Le blanchiment de capitaux figurant explicitement, au chapitre 6, parmi les manquements nés d'une gouvernance déficiente, en quel sens ce chapitre peut-il être lu comme une étude approfondie, *a priori*, du dispositif de gouvernance dont l'absence a précisément permis le manquement que le chapitre 6 documente *a posteriori* ?
- (d) Le chapitre 5 distingue trois strates de reporting — « à la base, un reporting très détaillé sert à surveiller l'activité au quotidien [...] au sommet, un reporting synthétique, très sélectif, permet de décider des orientations stratégiques (niveau conseil d'administration) » — et précise qu'un incident isolé ne remonte au conseil, sous forme de « seule sa conclusion », que « s'il révèle une faiblesse structurelle de contrôle affectant l'appétit pour le risque de l'organisation ». Ce chapitre exige que « le conseil d'administration [...] reçoive une information suffisamment complète, compréhensible et exacte pour prendre des décisions éclairées » sur les risques ML/FT, sans jamais préciser que le conseil devrait être informé du détail de chaque déclaration individuelle à la cellule de renseignement financier. Montrer que l'information exigée par ce chapitre au niveau du conseil correspond très précisément à la strate « synthétique, très sélective » du sommet du « gâteau du reporting » du chapitre 5, et non à la strate « très détaillée » de la base, où se logerait naturellement le traitement opérationnel de chaque alerte ou déclaration individuelle. Le processus « d'identification, d'investigation et de déclaration des transactions suspectes » de ce chapitre devant rester confidentiel vis-à-vis du client selon (a), à quelle strate du modèle du chapitre 5 — opérationnelle, management, ou conseil — ce traitement individuel des déclarations appartient-il nécessairement, et pourquoi la confidentialité exigée par ce chapitre est-elle, dans cette strate précise, plus aisée à préserver que si chaque déclaration devait remonter en détail jusqu'au conseil d'administration ?

3 Applications en sciences économiques

Exercice 5 — Alertes, faux positifs et déclarations à la FIU, chiffrés

Une banque segmente son portefeuille de clients en quatre catégories pour son système de surveillance informatisé des transactions. Pour chaque catégorie, elle dispose du nombre de comptes (n), du taux d'alerte annuel par compte, du coût d'investigation par alerte (temps de conformité de premier examen), et du taux de conversion d'une alerte en déclaration effective à la cellule de renseignement financier (FIU) :

Catégorie	Comptes n	Taux d'alerte annuel	Coût / alerte (€)	Conversion en déclaration
Particuliers	100 000	0,30 %	40	2 %
PME	15 000	1,00 %	60	10 %
Grandes entreprises	2 000	2,50 %	120	20 %
Risque élevé (PPE / non-résidents)	500	15,00 %	250	40 %

- Pour chaque catégorie, calculer le nombre d'alertes annuelles (comptes $\times$ taux d'alerte) et le coût total d'investigation associé (alertes $\times$ coût par alerte). Calculer le nombre total d'alertes et le coût total d'investigation du portefeuille.
- Pour chaque catégorie, calculer le nombre de déclarations effectives à la FIU (alertes $\times$ taux de conversion) et sa part dans le nombre total de déclarations du portefeuille. Calculer le taux de conversion global du portefeuille (déclarations totales / alertes totales). Quelle catégorie produit, à elle seule, la plus grande part des déclarations effectives, alors même qu'elle ne représente qu'une infime fraction du nombre de comptes ?
- Calculer, pour chaque catégorie, le coût d'investigation par déclaration effective (coût total de la catégorie / nombre de déclarations de la catégorie), ainsi que ce même ratio pour le portefeuille dans son ensemble. Classer les quatre catégories de la moins à la plus « productive » au sens de ce ratio. Le classement par coût par déclaration coïncide-t-il avec le classement par nombre brut d'alertes établi au (a) ?
- La banque envisage un projet de réglage fin des seuils d'alerte pour la seule catégorie « Particuliers », capable de réduire de 40 % le nombre d'alertes de cette catégorie en n'éliminant que des faux positifs (le nombre de déclarations effectives de cette catégorie reste inchangé). Ce projet coûte 25 000 € par an. Calculer le nouveau nombre d'alertes et le nouveau coût d'investigation de la catégorie « Particuliers », la réduction de coût ainsi obtenue, le bénéfice net du projet (réduction de coût moins coût du projet) et le ratio bénéfice/coût. Ce projet est-il économiquement justifié sur le seul critère de la réduction du coût d'investigation ? Recalculer le nouveau coût par déclaration du portefeuille entier après ce réglage, et commenter l'écart avec le coût par déclaration initial calculé au (c).

Exercice 6 — Diligence renforcée, PPE et conservation des dossiers, chiffrés

Une banque accueille chaque année trois catégories de nouveaux clients, avec un temps de traitement de base (dossier KYC standard) et un temps additionnel de diligence renforcée pour les catégories à risque élevé, facturé au coût horaire de conformité de 60 €/heure :

Catégorie	Nouveaux clients n	Temps de base (h)	Temps additionnel de diligence renforcée
Standard	8 000	1,0	0
Risque élevé (non-PPE)	600	1,0	2,0
PPE étrangère	50	1,0	5,0

Chaque dossier PPE requiert en outre une approbation formelle par la direction générale, exigeant 2

heures de comité par dossier au coût horaire de 250 €/heure (temps de direction générale). Par ailleurs, la conservation de tout dossier client coûte 8 € par an, pour une durée minimale de cinq ans après la fin de la relation ; parmi les dossiers PPE, 20 % font l'objet d'un litige ou d'une enquête en cours et voient leur durée de conservation prolongée de trois années supplémentaires (huit ans au lieu de cinq).

- (a) Pour chaque catégorie, calculer le temps total de traitement (base + diligence renforcée, en heures, multiplié par n) et le coût de conformité associé (au taux de 60 €/heure). Calculer le temps total et le coût total de conformité du portefeuille des trois catégories.
- (b) Calculer le coût total de l'approbation par la direction générale pour l'ensemble des dossiers PPE de l'année.
- (c) Calculer le coût total (conformité et, pour les PPE, approbation par la direction générale) de chaque catégorie, ainsi que le coût moyen par dossier de chaque catégorie. Calculer le rapport entre le coût moyen par dossier de chaque catégorie à risque et celui de la catégorie standard. Ce rapport pour la catégorie PPE reflète-t-il uniquement le temps de diligence renforcée, ou également le coût de l'approbation par la direction générale ?
- (d) Calculer le coût de conservation, sur la durée minimale de cinq ans, de la cohorte annuelle complète des nouveaux clients (les trois catégories confondues). Calculer ensuite le coût additionnel de l'extension de conservation à huit ans pour les dossiers PPE en litige, et la part que cette extension représente dans le coût total de conservation. Calculer enfin le coût global du dispositif pour la cohorte annuelle (diligence renforcée et approbation, plus conservation) et la part qu'y représente la seule conservation des dossiers.